

NOVATECH IDENTITY & ACCESS MANAGEMENT SECURITY LAB

Microsoft Entra ID • Azure RBAC • SAML SSO • Identity Governance • Monitoring

Final Cybersecurity Portfolio Project Report

Author: Harsh Chaudhary

Project type: Hands-on IAM / cloud security lab

Completion date: 3 September 2026

Environment: Microsoft Entra ID and Microsoft Azure

Public-release note: account identifiers, tenant/subscription IDs, request IDs, IP addresses and certificate details are intentionally generalized or omitted.

Report Overview

This report documents the completed NovaTech IAM Security Lab using only actions and outcomes evidenced in the project workspace. Where the original portfolio plan included activities that were not evidenced in the executed lab, they are explicitly marked as future enhancements rather than presented as completed work.

Section	Content
1-5	Executive summary, business scenario, objectives and scope
6-9	Architecture, identity design, groups/roles and chronological implementation
10-18	Sign-in analysis, SAML SSO, Azure RBAC, storage security, audit, monitoring, JML, access governance and least privilege
19-24	Security findings, troubleshooting, limitations, skills/framework mapping and lessons learned
25-28	Outcome, conclusion, evidence index and GitHub documentation plan

Evidence Integrity Statement

The project conversation explicitly confirmed later numbered phases, including Phase 7 (SAML/SSO work), Phase 10 (audit and monitoring work), and Phase 11 (manual access review/governance). Earlier exact phase labels are not fully preserved in the visible workspace context. To avoid fabricating phase titles or numbering, Section 9 reconstructs the implementation chronologically as verified workstreams and only uses explicit phase numbers where they are supported.

2. Executive Summary

NovaTech was used as a fictional small-enterprise scenario to build a practical identity and access management environment in Microsoft Entra ID and Microsoft Azure. The security problem addressed by the lab was excessive or stale access across the identity lifecycle: users may be provisioned with more privilege than required, retain access after changing duties, or keep access after leaving. The lab therefore focused on identity creation, security-group design, role assignment, enterprise application access, SAML single sign-on, Azure resource authorization, auditability, monitoring and access review.

The completed environment contained five test identities: Alice Morgan, Daniel Lee, Ethan Wilson, Sophia Patel and the lab administrator account. Five cloud security groups were created: SG-Cloud-Admins, SG-Developers, SG-Finance, SG-IT-Support and SG-Security-Team. Role-based access was then demonstrated with Entra directory roles and Azure RBAC. Daniel Lee was assigned Helpdesk Administrator and SG-IT-Support access; Sophia Patel was assigned Security Reader and SG-Security-Team membership; Alice Morgan was retained as a minimal SG-Security-Team member; Ethan Wilson was used as the leaver/offboarding case; and the administrator account held Global Administrator plus Azure Subscription Owner for lab administration.

Application access was tested through a non-gallery enterprise application named NovaTech HR Portal and the Microsoft Entra SAML Toolkit. SAML 2.0 integration required configuration of the Entity ID, Assertion Consumer Service (ACS) URL, service-provider sign-on URL, Entra login/identifier values, certificate and NameID claims. Early tests produced errors, which led to correction of the connection-specific ACS/sign-on URLs and confirmation that the NameID format was emailAddress. Successful interactive sign-ins for Daniel Lee were subsequently visible in Entra sign-in logs. A separate access-denied test with Sophia Patel produced AADSTS50105 because the application required assignment and Sophia was not assigned, demonstrating application-level authorization.

Azure authorization was tested with a storage account. Daniel first held Reader access, then received temporary Contributor access. The elevated role enabled a storage configuration update that was captured in Azure Activity Log and change history. The evidence showed a successful minimum TLS version change from TLS 1.0 to TLS 1.2 and other configuration metadata. Contributor was later removed and Daniel returned to Reader-only access. Monitoring was added with an Azure Monitor Activity Log alert for successful administrative operations and an email action group. Finally, because native Entra Access Reviews were unavailable in the tenant, a manual access review was performed for all five identities. The final review confirmed justified access, complete offboarding for Ethan, and documented the high-risk concentration of Global Administrator plus Subscription Owner on the lab administrator account.

Overall, the project achieved its practical IAM and cloud-access objectives and produced evidence suitable for a cybersecurity portfolio. It also exposed important production considerations: privileged roles should not remain standing where just-in-time access is available; public repositories should sanitize identifiers; and premium governance capabilities such as automated access reviews should be used where licensing permits.

3. Project Background and Business Scenario

NovaTech is a fictional organization created for this lab. The scenario assumes a small cloud-enabled company with IT support, finance, security and development functions. The organization needs a repeatable way to control who can sign in, which groups and applications users can access, which administrative roles they hold, and what Azure resources they can modify.

The original portfolio problem statement was that joiner/mover/leaver failures and excessive access create fraud and data-exposure risk. The planned lifecycle was: business request -> identity/group/role assignment -> access review -> revoke or retain. The completed lab preserved that core objective while adding hands-on SAML SSO, Azure Storage RBAC, audit investigation and Azure Monitor alerting.

4. Project Objectives

- Create a small, role-based Microsoft Entra ID tenant suitable for IAM practice.
- Model user personas for IT support, finance and security functions.
- Create security groups that represent business and technical roles.
- Apply Entra directory roles using least-privilege reasoning.
- Configure enterprise application assignments and test authorization boundaries.
- Implement and troubleshoot a SAML 2.0 SSO integration.
- Investigate successful and failed sign-ins using Entra sign-in logs.
- Demonstrate Azure RBAC by comparing Reader and Contributor permissions.
- Capture administrative changes in Azure Activity Log and change history.
- Create monitoring for successful administrative operations and route notifications through an action group.
- Demonstrate offboarding by disabling an account and removing residual access.
- Perform a periodic access review, using a manual process when native Access Reviews were unavailable.
- Document residual risks and production-grade recommendations.

Original Portfolio Items Not Evidenced as Completed

The original project tracker also proposed PowerShell/Graph access-inventory scripting, Jira-based access tickets, a formal segregation-of-duties conflict exercise, emergency-access documentation and Conditional Access design. The current workspace does not contain sufficient evidence that those items were completed in this build. They are therefore not claimed as completed and are listed later as future enhancements.

5. Scope

In Scope	Out of Scope / Not Evidenced
Microsoft Entra users, groups, directory roles and application assignments	Production identities or real employee data
SAML 2.0 integration using Microsoft Entra SAML Toolkit	Custom application development
Sign-in log investigation	Full SOC/SIEM integration with Sentinel
Azure Storage account and Azure RBAC	Production Azure workloads
Reader-to-Contributor privilege test and de-escalation	PIM/JIT role activation
Activity Log and change-history analysis	Automated Graph/PowerShell inventory
Azure Monitor administrative alert + email action group	Ticketing workflow / Jira evidence
Manual access review and offboarding validation	Native automated Access Reviews (tenant unavailable)

6. Lab Architecture

NovaTech IAM Security Lab - Logical Architecture

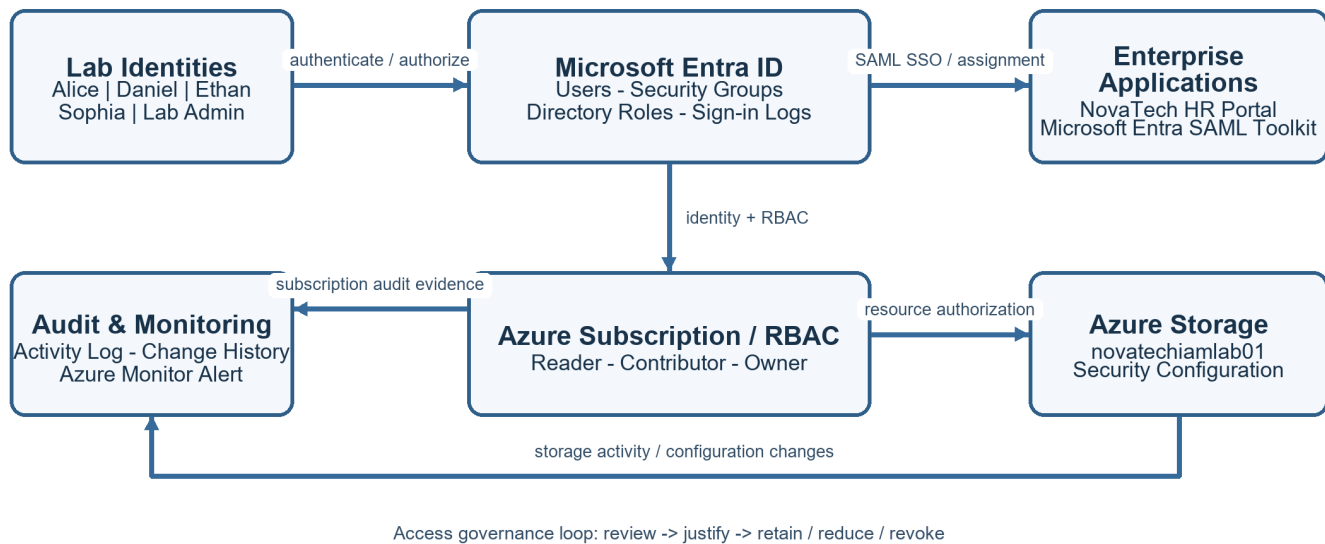


Figure 1. Logical architecture reconstructed from the completed lab.

The architecture separates identity, application access, Azure authorization and monitoring. Microsoft Entra ID is the identity provider. Security groups and directory roles represent organizational access. Enterprise applications rely on direct user assignment and, for the SAML Toolkit, SAML 2.0 federation. Azure RBAC controls access to the storage account. Azure Activity Log and Azure Monitor provide the audit and detection layer.

- Identity plane: Entra users, groups, directory roles and sign-in logs.
- Application plane: NovaTech HR Portal and Microsoft Entra SAML Toolkit.
- Resource plane: Azure subscription, resource group and storage account novatechiamlab01.
- Authorization plane: Azure RBAC roles including Reader, temporary Contributor and Subscription Owner.
- Monitoring plane: Activity Log, change history and administrative-operation alerting.

7. Identity Design

Identity	Lab business function	Final state	Key access
Harsh Chaudhary (Lab Administrator)	Tenant / subscription administration	Enabled	Global Administrator; Azure Subscription Owner
Daniel Lee	IT support / helpdesk persona	Enabled	SG-IT-Support; Helpdesk Administrator; NovaTech HR Portal; SAML Toolkit; Azure Reader on storage
Sophia Patel	Security monitoring persona	Enabled	SG-Security-Team; Security Reader
Alice Morgan	Security team member persona	Enabled	SG-Security-Team only
Ethan Wilson	Finance / leaver persona	Disabled	No groups, apps, directory roles, Azure RBAC or licenses

These are lab personas used to demonstrate access decisions. They are not presented as real NovaTech employees.

8. Group and Role Design

Security Group	Purpose / Evidence
SG-Cloud-Admins	Created as a cloud-administration role group; no final member assignment is claimed from available evidence.
SG-Developers	Created as a development-function group; no final member assignment is claimed from available evidence.
SG-Finance	Finance-role group. Ethan Wilson had previously been associated with finance access and was later removed during offboarding.
SG-IT-Support	Daniel Lee's verified security-group membership.
SG-Security-Team	Verified membership for Sophia Patel and Alice Morgan.

Directory Roles

Identity	Directory role	Least-privilege rationale
Daniel Lee	Helpdesk Administrator	Supports helpdesk duties without granting Global Administrator.
Sophia Patel	Security Reader	Read-only access to security information; no broad modification rights.
Alice Morgan	None	Group membership only; no unnecessary directory privilege.
Ethan Wilson	None	Offboarded identity retains no directory privilege.
Lab Administrator	Global Administrator	Required for lab build/administration; high-risk standing privilege in production.

Azure RBAC Roles

Identity	Azure role	Scope	Status
Daniel Lee	Reader	novatechiamlab01 storage account	Retained
Daniel Lee	Contributor	novatechiamlab01 storage account	Temporary; removed after testing
Lab Administrator	Owner	Azure subscription 1	Retained for lab administration
Sophia Patel	None	Selected subscription	No assignment
Alice Morgan	None	Selected subscription	No assignment
Ethan Wilson	None	Selected subscription	No assignment

9. Project Implementation - Verified Chronological Workstreams

The implementation is presented chronologically. The report does not manufacture missing early phase labels. Explicit workspace references confirm Phase 7, Phase 10 and Phase 11; all other entries below are described as verified workstreams.

Workstream A - Tenant identity foundation

Objective: Create test identities and establish the fictional NovaTech role model.

Configuration / test: Five identities were present: Alice Morgan, Daniel Lee, Ethan Wilson, Sophia Patel and the lab administrator.

Result: Identity inventory established and later used for access review.

Workstream B - Security groups and role-based access

Objective: Create role-oriented security groups and map users to job functions.

Configuration / test: Five security groups were present. Daniel was verified in SG-IT-Support; Sophia and Alice in SG-Security-Team; Ethan's finance access was removed during offboarding.

Result: Group-based access and least-privilege role design were demonstrated.

Workstream C - Directory roles

Objective: Assign administrative roles that match job functions.

Configuration / test: Daniel received Helpdesk Administrator; Sophia received Security Reader; the lab administrator held Global Administrator.

Result: Demonstrated separation between support, security-read and full administration.

Workstream D - Application assignment and authorization

Objective: Create enterprise applications and control who is allowed to use them.

Configuration / test: NovaTech HR Portal was created as an enterprise application. Daniel was directly assigned. Microsoft Entra SAML Toolkit was also assigned to Daniel.

Result: Direct assignment became important during SSO testing; unassigned Sophia was blocked.

Workstream E - Sign-in investigation

Objective: Inspect authentication outcomes and contextual sign-in data.

Configuration / test: Failed sign-in evidence for Sophia showed error 50126 invalid username/password, Sydney location and an unmanaged Android/Chrome mobile client. Later SAML Toolkit logs showed successful Daniel sign-ins.

Result: Demonstrated authentication troubleshooting through Entra logs.

Phase 7 - SAML SSO configuration and troubleshooting

Objective: Configure SAML 2.0 federation with Microsoft Entra SAML Toolkit.

Configuration / test: Entity ID, ACS URL, sign-on URL, Entra Login URL, Entra Identifier, raw certificate and NameID emailAddress claim were configured. Connection-specific URLs using connection ID 22301 were applied.

Result: Initial response errors were resolved and Daniel's interactive SSO sign-ins were recorded as successful.

Workstream F - Azure Storage resource creation

Objective: Create a cloud resource for resource-level authorization testing.

Configuration / test: Storage account novatechiamlab01 was created in resource group rg-novatech-iam-lab in Australia East / East US display context as shown in Azure.

Result: Provided a real Azure object on which RBAC and security configuration could be tested.

Workstream G - Reader vs Contributor authorization

Objective: Demonstrate that read-only and modification privileges differ.

Configuration / test: Daniel was first assigned Reader, then temporary Contributor. Contributor allowed a successful storage configuration update; the temporary role was later deleted and Reader retained.

Result: Demonstrated privilege escalation, authorized change, and privilege de-escalation.

Workstream H - Storage security configuration test

Objective: Inspect and change meaningful storage security controls.

Configuration / test: Minimum TLS version was successfully changed from TLS 1.0 to TLS 1.2. Other storage configuration controls were tested, and the final visible state included secure transfer enabled, anonymous blob access disabled, Entra authorization enabled and storage account key access enabled.

Result: Demonstrated the difference between configuration visibility and configuration write capability.

Phase 10 - Audit trail and monitoring

Objective: Investigate administrative actions and create detection coverage.

Configuration / test: Azure Activity Log identified the actor, resource and operations. Change history exposed before/after configuration values. An Azure Monitor alert rule for successful Administrative operations and an email action group were created.

Result: Created evidence of accountability and proactive monitoring.

Phase 11 - Manual access review and governance

Objective: Validate that every identity's current access is still justified.

Configuration / test: Native Access Reviews returned 'You don't have access' (401). A manual review was completed for all five identities using Overview, Groups, Assigned roles, Applications and Azure role assignments.

Result: Governance objective achieved manually with documented residual risk.

10. Authentication and Sign-in Investigation

Failed Sign-in Case - Sophia Patel

Field	Observed value
Status	Failure
Sign-in error code	50126
Failure reason	Error validating credentials due to invalid username or password
Authentication requirement	Single-factor authentication
Application	Microsoft Authentication Broker
Client	Mobile Apps and Desktop clients
Location	Sydney, New South Wales, Australia
Device	Android with Chrome Mobile; device not managed and not compliant
IP address	Captured in evidence; redacted from public report

The failure demonstrated how Entra sign-in logs separate credential failure from application authorization. The log contained identity, client, device, location and error information that can support troubleshooting or security triage.

Application Authorization Case - Sophia Patel

When Sophia attempted to access Microsoft Entra SAML Toolkit, Entra returned AADSTS50105. The application required user assignment and Sophia was not directly assigned or a member of an assigned group. This was a successful negative authorization test: authentication could proceed to the application boundary, but authorization was denied because assignment was missing.

Successful SSO Case - Daniel Lee

After SAML configuration was corrected, the Microsoft Entra SAML Toolkit sign-in log showed multiple successful interactive sign-ins for Daniel Lee. This confirmed that the SAML configuration, application assignment and identity matching were working together.

11. SAML SSO Implementation

SAML element	Verified configuration
Enterprise application	Microsoft Entra SAML Toolkit
Entity ID	https://samltoolkit.azurewebsites.net
Final ACS / Reply URL	https://samltoolkit.azurewebsites.net/SAML/Consume/22301
Final SP Sign-on URL	https://samltoolkit.azurewebsites.net/SAML/Login/22301

Entra Login URL	https://login.microsoftonline.com/<tenant>/saml2
Entra Identifier	https://sts.windows.net/<tenant>/
Certificate	Raw SAML signing certificate downloaded from Entra and uploaded to the toolkit
NameID format	Email address
NameID source	user.userprincipalname
Assigned test user	Daniel Lee

Troubleshooting Sequence

1. Initial SAML configuration used generic toolkit URLs and produced a SAML processing error after the response was posted.
2. The toolkit's connection-specific configuration page generated an SP Initiated Login URL and ACS URL containing connection ID 22301.
3. The Entra Basic SAML Configuration was updated to the connection-specific ACS and sign-on URLs.
4. The NameID claim was checked and configured as Email address using user.userprincipalname.
5. The toolkit-side IdP configuration was populated with the Entra Login URL, Entra Identifier, Logout URL and raw certificate.
6. Daniel Lee, who was directly assigned to the application, successfully authenticated and appeared in Entra sign-in logs.

Final Outcome

The SAML configuration was successful. Early failures were configuration troubleshooting events rather than a final project failure. Successful Entra sign-in records for Daniel confirmed the final working state.

12. Azure RBAC and Least-Privilege Testing

Azure RBAC was tested on the storage account novatechiamlab01. The core scenario compared a read-only Reader assignment with a temporary Contributor assignment.

Stage	Daniel's role	Observed capability / outcome
Baseline	Reader	Storage account visible; configuration changes could not be committed.
Temporary elevation	Contributor	Contributor assignment created at the storage-account scope.
Change test	Contributor	A storage-account update was successfully initiated by Daniel and captured in Activity Log.
De-escalation	Reader	Contributor role assignment deleted; Reader remained as final assignment.

This sequence demonstrates privilege lifecycle management: grant elevated rights only for the task, verify the activity, then remove the elevation. It also provides a clear before/after example for interview discussion of least privilege.

13. Azure Storage Security Configuration

Control	Observed / final evidence	Interpretation
Secure transfer required	Enabled in final configuration screenshot	HTTPS-only transport requirement retained.
Minimum TLS version	Changed from TLS 1.0 to TLS 1.2 and retained	Successful security hardening change captured in change history.
Blob anonymous access	Disabled in final configuration	Reduces unintended public blob exposure.
Default to Microsoft Entra authorization	Enabled in final configuration	Encourages identity-based authorization in Azure Portal.
Storage account key access	Enabled in final configuration	Shared-key authentication remained available; production environments should restrict where feasible.
Managed Identity for SMB	Enabled in final configuration	Identity-based SMB setting was visible as enabled.
SAS upper-limit policy	Testing occurred; final visible upper-limit	Transient test settings were not all retained.

toggle was disabled

During the permission test, multiple configuration toggles were manipulated to determine whether Daniel could save changes. Not every temporary test state was intended as a final security baseline. The report therefore treats the Activity Log/change-history evidence as authoritative for confirmed saved changes and the final Configuration screenshot as authoritative for the visible final state.

14. Audit Trail and Configuration-Change Investigation

Activity Log Evidence

The Azure Activity Log provided a record of administrative operations against the storage account. Relevant events included create role assignment, delete role assignment and Update Storage Account Create. The event detail showed the initiating identity, resource, operation and timestamp.

Event	Key evidence
Create role assignment	Microsoft.Authorization/roleAssignments/write; succeeded with HTTP status 201 in JSON evidence.
Update Storage Account Create	Initiated by Daniel Lee; succeeded; resource was novatechiamlab01.
Delete role assignment	Role shown as Contributor; scope shown as resource novatechiamlab01; initiated by lab administrator.

Change History Evidence

The Change history view displayed before/after JSON for the storage resource. The most important confirmed change was minimumTlsVersion from TLS1_0 to TLS1_2. The after-state also showed additional storage configuration metadata such as defaultToOAuthAuthentication and SAS policy settings. This provided stronger evidence than simply observing the portal configuration screen because it recorded the actual resource change.

15. Monitoring and Alerting

An Azure Monitor Activity Log alert was created for the storage account to detect successful Administrative operations. Because the storage-account alert wizard exposed a broad Administrative signal rather than a clean operation-name filter for only role assignment changes, the final rule intentionally monitored successful administrative activity at the resource scope.

Alert component	Configuration
Scope	novatechiamlab01 storage account
Signal	All Administrative operations
Status filter	Succeeded only
Event initiator	All services and users
Action group	ag-novatech-security-alerts
Notification	Email via SecurityEmail notification
Purpose	Notify the lab owner when successful administrative changes occur on the storage account

This is broader than a dedicated RBAC-only detection, but it improves visibility for both permission changes and resource configuration changes. In production, a Log Analytics query or policy/SIEM workflow could be used for more precise operation-level detection.

16. Identity Lifecycle / Joiner-Mover-Leaver (JML)

The strongest lifecycle evidence in the completed lab is Ethan Wilson's leaver scenario. Ethan's account was disabled and all residual access was removed.

Offboarding control	Final Ethan state
---------------------	-------------------

Account status	Disabled
Group memberships	0
Enterprise applications	0
Assigned directory roles	0
Azure role assignments	0
Assigned licenses	0

This is the target state for a clean leaver process: prevent new authentication and remove the permissions, application assignments and licenses that could otherwise remain as orphaned access.

17. Access Review and Identity Governance

Native Feature Limitation

The Entra Identity Governance > Access reviews page returned 'You don't have access' with error code 401. Because native Access Reviews could not be used in this tenant/session, the governance objective was completed with a manual review.

Manual Access Review Method

For each identity, the following views were checked: Overview, Assigned roles, Groups, Applications and Azure role assignments. The reviewer then recorded a retain/revoke decision and justification.

User	Account	Group	Directory role	Azure RBAC	Apps	Decision	Risk / justification
Ethan Wilson	Disabled	None	None	None	None	REVOKE / keep disabled	Low residual risk; offboarding complete.
Daniel Lee	Enabled	SG-IT-Support	Helpdesk Administrator	Reader on storage	NovaTech HR Portal; SAML Toolkit	KEEP justified access	Moderate: privileged helpdesk role, but aligned to lab function; temporary Contributor removed.
Sophia Patel	Enabled	SG-Security-Team	Security Reader	None	None	KEEP	Low-moderate: read-only security visibility matches role.
Alice Morgan	Enabled	SG-Security-Team	None	None	None	KEEP	Low: minimal group-only access.
Lab Administrator	Enabled	None	Global Administrator	Subscription Owner	None	KEEP for lab	High: concentration of tenant + subscription control; production design should reduce standing privilege.

18. Least-Privilege Analysis

- Reader vs Contributor: Daniel's final Reader role provides visibility without resource modification. Contributor was granted only for the test and later removed.
- Security Reader: Sophia can inspect security information without broad administrative write privileges.

- Helpdesk Administrator: Daniel has more privilege than a standard user, but the role is narrower than Global Administrator and aligns to the IT-support persona.
- Global Administrator + Subscription Owner: the lab administrator has standing control of both the identity tenant and Azure subscription. This is acceptable for a single-user lab but is a high-risk concentration in production.
- Disabled leaver: Ethan has no residual entitlements, reducing orphaned-account risk.

Production Recommendations

- Use separate day-to-day and privileged administrator accounts.
- Require phishing-resistant MFA for privileged identities where available.
- Use Microsoft Entra PIM for eligible, time-bound activation of Global Administrator and other sensitive roles.
- Use access reviews on a scheduled basis when the required Entra governance licensing is available.
- Prefer identity-based Azure authorization and reduce Shared Key use where operationally feasible.
- Monitor roleAssignments/write and roleAssignments/delete at subscription/resource-group scope using Log Analytics/SIEM for more precise detection.

19. Security Findings

ID	Finding	Severity	Evidence	Impact	Recommendation	Final status
F-01	Standing dual-control administrator (Global Administrator + Subscription Owner)	High	Admin access review	Compromise could affect both identity and Azure resource planes	Separate admin identities; PIM/JIT; strong MFA; monitor privileged changes	Accepted for lab / mitigate in production
F-02	Native automated Access Reviews unavailable	Medium	Access Reviews page returned 401 / no access	Periodic governance depends on manual process	Use appropriate Entra Governance/P2 licensing and scheduled reviews	Compensating manual review completed
F-03	Storage account originally allowed TLS 1.0	Medium	Azure change history	Legacy protocol configuration weakens transport baseline	Minimum TLS 1.2 or later	Remediated to TLS 1.2
F-04	Storage account key access remained enabled	Medium	Final storage configuration	Shared keys can bypass per-user identity controls if exposed	Disable Shared Key where workload compatibility allows; prefer Entra ID	Open / accepted for lab
F-05	SAML app required explicit assignment	Informational / Positive control	AADSTS50105 for unassigned Sophia	Prevents unauthorized user access to assigned-only enterprise app	Retain assignment-required design and review assignments	Control validated
F-06	Temporary Contributor privilege created write capability	Medium	Activity Log update by Daniel while elevated	Excess standing Contributor would allow configuration changes	Retain Reader by default; elevate only when justified	Remediated: Contributor removed

20. Challenges and Troubleshooting

Challenge	What happened	Resolution / learning
Generic SAML URLs caused processing errors	A SAML response reached the toolkit but the service could not process the request correctly	Use the toolkit's connection-specific ACS and SP sign-on URLs containing connection ID 22301.

NameID requirements	Toolkit required a NameID in emailAddress format	Confirmed NameID format as Email address and source user.userprincipalname.
Application assignment boundary	Sophia could not access the SAML app	AADSTS50105 correctly indicated assignment was required; this became a negative authorization test.
Reader permission test	Daniel could view the resource but could not save configuration changes	Temporary Contributor role proved the difference between read and write authorization.
Portal role search confusion	Azure showed many specialized Contributor roles	Switched to the correct role category/search and selected the built-in Contributor role.
Configuration test cleanup	Multiple storage toggles were changed during testing	Temporary changes were reviewed and reverted as needed; final state was rechecked.
Native Access Reviews unavailable	Identity Governance Access reviews returned 401/no access	Completed a manual review across roles, groups, apps and Azure RBAC.
Broad Activity Log alert signal	Resource-level alert wizard offered All Administrative operations rather than precise RBAC operation filter	Created a broad succeeded-admin alert and documented a future SIEM/Log Analytics refinement.

21. Limitations

- This is a single-tenant portfolio lab, not a production enterprise deployment.
- Native Entra Access Reviews were not available in the current tenant/session; governance was performed manually.
- Conditional Access implementation is not claimed as completed because the workspace does not contain sufficient execution evidence.
- PowerShell/Graph access-inventory scripting from the original portfolio plan is not claimed as completed.
- Formal Jira request/approval tickets, segregation-of-duties conflict testing and emergency-access procedures are not evidenced in this build.
- Azure Monitor alerting was broad at the storage-resource scope rather than a dedicated operation-specific RBAC detection.
- Application SSO used Microsoft's public SAML Toolkit rather than a custom business application.
- Some administrative privileges remained standing because this was a single-user lab without PIM/JIT governance.

22. Skills Demonstrated

Skill	Evidence from project	Relevant roles
Microsoft Entra ID administration	Users, groups, directory roles, enterprise apps, sign-in logs	IAM Analyst; Service Desk; Cloud Security
RBAC and least privilege	Reader vs temporary Contributor; Security Reader; Helpdesk Administrator	IAM Analyst; Cloud Security Analyst
SAML 2.0 / SSO	Entity ID, ACS, sign-on URL, certificate, NameID claims, troubleshooting	IAM Analyst; Identity Security Analyst
Identity lifecycle / JML	Ethan offboarding and residual-access validation	IAM Analyst; Access Administrator
Access governance	Manual review of every identity's roles, groups, apps and Azure RBAC	IAM/GRC Analyst
Azure security administration	Storage security configuration, resource RBAC, Activity Log	Cloud Security Analyst; Junior Security Engineer
Audit and investigation	Sign-in logs, Activity Log JSON, change history	SOC Analyst; Security Analyst
Monitoring	Azure Monitor Activity Log alert and email action group	SOC / Cloud Security
Troubleshooting	SAML errors, assignment denial, role visibility and permission testing	IAM / Support / Security Operations
Security documentation	Evidence-driven findings, decisions, limitations and remediation	All target roles

23. Security Framework Mapping

The project was not built as a formal compliance assessment, but several controls align naturally with common security principles.

Framework / principle	Project mapping
NIST AC-2 Account Management	User lifecycle, account disablement, group/role review and offboarding.
NIST AC-6 Least Privilege	Reader as final Azure role; limited Security Reader/Helpdesk roles; removal of temporary Contributor.
NIST AU-2 / AU-6 Audit Events and Review	Entra sign-in logs, Azure Activity Log and change-history investigation.
Zero Trust - Verify explicitly	Sign-in context and application assignment were evaluated rather than assuming network location alone.
Zero Trust - Use least privilege	Role-specific directory privileges and temporary Contributor access.
Zero Trust - Assume breach / monitor	Administrative Activity Log alert and evidence review.
CIS identity/access principles	Unique identities, least privilege, account lifecycle hygiene, reduced orphaned access and privileged-role review.

No MITRE ATT&CK technique mapping is forced here because the project primarily implemented preventive and governance controls rather than emulating a specific adversary technique.

24. Lessons Learned

- I learned that authentication and authorization are separate failure points: invalid credentials (50126) and application assignment denial (AADSTS50105) require different troubleshooting paths.
- SAML configuration is sensitive to the exact service-provider values. The Entity ID can be stable while ACS and sign-on URLs may be connection-specific.
- NameID formatting is not cosmetic; the service provider's identity-matching requirement determines whether the assertion can be consumed.
- Azure Reader and Contributor may look similar in the portal until a write action is attempted. Testing the actual operation is necessary to validate the control.
- Activity Log and change history are stronger evidence than screenshots alone because they show who changed what and whether the operation succeeded.
- Temporary privilege should be removed after the task. Returning Daniel to Reader provided a clear least-privilege end state.
- Offboarding is more than disabling the account; groups, applications, roles and licenses must also be checked for residual access.
- When premium governance features are unavailable, a documented manual access review is better than skipping governance entirely, but it should be treated as a compensating control rather than equivalent automation.
- An administrator account with both tenant-wide and subscription-wide control is convenient in a lab but should trigger strong production safeguards.

25. Project Outcome

The core project objective was achieved: a working Microsoft Entra ID and Azure IAM lab was built and used to demonstrate identity administration, role-based access, enterprise application authorization, SAML SSO, Azure resource authorization, audit investigation, monitoring, offboarding and periodic access review.

Objective	Outcome
Identity and group administration	Achieved
Role-based access / least privilege	Achieved
SAML SSO	Achieved after troubleshooting
Sign-in investigation	Achieved
Azure RBAC test	Achieved
Privilege de-escalation	Achieved
Azure audit/change investigation	Achieved

Monitoring and notification	Achieved with broad Administrative Activity Log alert
Offboarding	Achieved
Access review	Achieved manually due native feature limitation
Conditional Access implementation	Not claimed / insufficient evidence
PowerShell/Graph inventory automation	Not claimed / future enhancement
Jira approvals / SoD / emergency access	Not claimed / future enhancement

26. Conclusion

The NovaTech IAM Security Lab moved beyond a simple user-creation exercise by connecting identity decisions to application access, cloud resource permissions, audit evidence and governance. The strongest technical demonstration was the complete privilege lifecycle around Daniel Lee: baseline Reader access, temporary Contributor elevation, a successful configuration change attributable in Azure Activity Log, and subsequent removal of Contributor. The SAML work also provided realistic troubleshooting evidence, including a failed response-processing state, corrected service-provider configuration, a negative assignment test and successful sign-ins.

The final access review showed a defensible end state: Ethan was fully offboarded, Alice retained minimal group access, Sophia retained read-only security visibility, Daniel retained support-oriented access with Reader-only Azure permissions, and the lab administrator's high privilege was explicitly documented as a production risk. This combination of implementation, testing, troubleshooting and evidence review makes the project suitable for IAM, service desk, SOC and junior cloud-security portfolio discussions.

27. Evidence / Screenshot Index

The following evidence was captured during the project conversation. Before publishing publicly, crop screenshots to the relevant control and redact tenant/subscription/object/request/correlation IDs, personal email addresses, raw certificates and unnecessary IP addresses.

Evidence ID	Screenshot / evidence	Report section	Public-release action
E01	Entra sign-in Activity Details - Sophia failure, error 50126	10	Redact UPN, IP, request/correlation IDs.
E02	Sign-in Location / Device / Authentication details	10	Redact IP and identifiers; keep Sydney/Android context.
E03	NovaTech HR Portal enterprise application overview and assigned user	8 / 11	Redact application/object IDs.
E04	Microsoft Entra SAML Toolkit user assignment	11	Redact UPN/IDs.
E05	Basic SAML Configuration before and after connection-specific URLs	11	Retain public toolkit URLs; redact tenant identifiers.
E06	SAML Toolkit IdP configuration with Entra values and certificate selection	11	Do not publish certificate body; redact tenant identifiers.
E07	SAML processing error screenshot	11 / 20	Safe after redacting response payload.
E08	NameID claim configuration - emailAddress / user.userprincipalname	11	Safe with tenant/user identifiers cropped.
E09	Successful SAML Toolkit sign-in log entries for Daniel	10 / 11	Redact UPN/IP/request IDs.
E10	Sophia AADSTS50105 assignment-denied page	10	Redact UPN/request IDs.
E11	Storage account creation / overview	12 / 13	Redact subscription ID if visible.
E12	Daniel Reader role assignment	12 / 17	Redact object IDs.
E13	Temporary Contributor assignment review screen	12	Redact object ID / subscription ID.
E14	Daniel portal view as Reader and configuration save restriction	12 / 20	Redact account identifiers.
E15	Daniel portal after Contributor elevation	12	Redact account identifiers.
E16	Storage Configuration final state	13	Safe after redacting

			account/subscription details.
E17	Azure Activity Log listing administrative operations	14	Redact personal email addresses if publishing.
E18	Update Storage Account Create event initiated by Daniel	14	Redact resource subscription path and UPN.
E19	Change History before/after JSON showing TLS1_0 -> TLS1_2	13 / 14	Crop to relevant properties; redact subscription/resource IDs.
E20	Delete role assignment event - Contributor	12 / 14	Redact resource path and personal email.
E21	Create role assignment Activity Log JSON	14	Redact token/claim details and identifiers.
E22	Azure Monitor alert rule - All Administrative operations / Succeeded	15	Redact tenant/resource identifiers.
E23	Action group ag-novatech-security-alerts with SecurityEmail	15	Redact destination email.
E24	Identity Governance Access Reviews 401 / no access	17 / 21	Redact session/error identifiers if present.
E25	Ethan Overview - disabled, 0 groups/apps/roles/licenses	16 / 17	Redact UPN/object ID.
E26	Daniel Groups / Assigned Roles / Applications / Azure role assignments	17	Redact UPN/object ID.
E27	Sophia Security Reader / SG-Security-Team / no apps / no Azure roles	17	Redact UPN/object ID.
E28	Alice SG-Security-Team / no roles/apps/Azure RBAC	17	Redact UPN/object ID.
E29	Lab admin Global Administrator + Subscription Owner	17 / 18 / 19	Redact UPN and subscription details.

28. GitHub Documentation Plan

The public repository should emphasize reproducible security reasoning, sanitized evidence and clear limitations rather than simply uploading portal screenshots.

Recommended repository structure:

```
novatech-entra-iam-lab/
├── README.md
├── docs/
│   ├── final-report.pdf
│   ├── architecture.md
│   ├── identity-and-role-design.md
│   ├── saml-sso-implementation.md
│   ├── azure-rbac-test.md
│   ├── audit-and-monitoring.md
│   ├── access-review.md
│   ├── findings.md
│   └── lessons-learned.md
├── diagrams/
│   └── novatech-iam-architecture.png
├── evidence/
│   ├── sign-in-investigation/
│   ├── saml-sso/
│   ├── azure-rbac/
│   ├── storage-security/
│   ├── monitoring/
│   └── access-review/
├── matrices/
│   ├── identity-role-matrix.md
│   └── access-review-matrix.md
└── SECURITY-NOTES.md
```


README Content Order

1. Project summary and business problem.
2. Architecture diagram.
3. Skills demonstrated.
4. Identity / role matrix.
5. Key implementation highlights: SAML SSO, Reader vs Contributor, audit/change history, monitoring and offboarding.
6. Security findings and final access-review results.
7. Known limitations and future enhancements.
8. Evidence index with sanitized screenshots.
9. Short 'What I would improve in production' section.

Future Enhancements

- Implement PowerShell or Microsoft Graph access inventory and compare script output to the manual review.
- Add Conditional Access design and implementation with MFA/device/risk controls where licensing permits.
- Use Entra PIM for eligible privileged roles and time-bound activation.
- Implement native scheduled Access Reviews when licensing is available.
- Create a segregation-of-duties scenario and formal exception process.
- Add Jira-style request/approval tickets or a simple documented access-request workflow.
- Forward Entra/Azure audit data into Microsoft Sentinel or another SIEM and create precise detections for role assignment changes.

Appendix A - Public Portfolio Summary

Built a hands-on Microsoft Entra ID and Azure IAM lab for a fictional company, NovaTech, covering identity lifecycle, role-based access, SAML SSO, Azure resource authorization, audit investigation, monitoring and access governance. Configured five user personas, role-oriented security groups and least-privilege directory roles. Implemented Microsoft Entra SAML Toolkit SSO, resolved ACS/Sign-on URL and NameID issues, and validated both successful SSO and assignment-denied behavior. Tested Azure Reader vs temporary Contributor on a storage account, captured the resulting configuration change in Activity Log/change history, removed elevated access, and retained Reader. Added an administrative-operation alert with email notification, fully offboarded a leaver identity, and completed a manual access review for all users when native Access Reviews were unavailable.

Appendix B - Resume-ready Project Bullets

- Built and documented a Microsoft Entra ID / Azure IAM lab with role-based users, security groups, Entra directory roles, enterprise application assignments and Azure RBAC.
- Configured and troubleshoot SAML 2.0 SSO using Microsoft Entra SAML Toolkit, including ACS/sign-on URLs, signing certificate and emailAddress NameID claims; validated successful and denied access scenarios.
- Demonstrated least privilege by elevating a user from Azure Reader to temporary Contributor for an authorized storage configuration change, verifying the change in Activity Log, and removing the elevated role.
- Investigated Entra sign-in failures and successful SSO events using authentication error codes, device/location context and application assignment evidence.
- Implemented Azure Activity Log monitoring with an email action group, completed leaver offboarding, and performed a manual identity access review across groups, roles, applications and Azure RBAC.

Appendix C - Consistency Check

Claims intentionally excluded from 'completed' status because the current workspace did not provide sufficient execution evidence: production Conditional Access policies, PIM activation, PowerShell/Graph inventory automation, Jira access tickets, formal segregation-of-duties testing, and emergency-access procedure testing. These are retained only as future enhancements.

Sensitive values intentionally generalized: tenant ID, subscription ID, object IDs, request IDs, correlation IDs, personal email addresses, IP address, certificate thumbprints and raw SAML certificate content.